

ETİK HACKER

10

Bir Etik Hacker, işletme sahiplerinin kötü niyetli bir bilgisayar korsanı tarafından keşfedilmeden önce güvenlik açıklarını düzeltmesine yardımcı olur.



Bu bölümü uygulamalı şekilde anlatmayı çoğu kere düşündüm ise de yasal olmayan sonuçlar ortaya çıkabileceğinden, çok teori az uygulama anlatımına yer verdim.

ETİK HACKİNG NEDİR?

Etik Hacking, bilgisayar sistemlerinde ve/veya bilgisayar ağlarında zayıflık tespit etmek ve zayıf yönlerini koruyan önlemler almaktır. Etik korsanlar aşağıdaki kurallara uymak zorundadır.

- Saldırı öncesi bilgisayar sisteminin ve/veya bilgisayar ağının sahibinden yazılı izin alın.
- Bilinen zayıflıkların tümünü bilgisayar sistemine saydam bir şekilde raporlayın.
- Tanımlanan zayıflıkları donanım ve yazılım satıcılarına bildirin.

Neden Etik Hacking?

Bilgi, bir organizasyonun en değerli varlıklarından biridir. Bilgileri güvenli tutmak, bir kuruluşun imajını koruyabilir.

Hacking Nedir?

Kullanmış olduğunuz sistem hakkında genel bilgi toplamak ve bu araçtaki tüm verilere ulaşmak yada kopyalamak amacıyla; sistem açıklarından faydalanarak bilgisayarınıza veya telefonunuza internet yoluyla izinsiz giriş yapılması olayına **hacking** adı verilir.

Bilgisayarlar, başarılı bir iş yürütmek için zorunlu hale geldi. İzole bilgisayar sistemlerine sahip olmak yeterli değildir; dış işletmelerle olan iletişimi kolaylaştırmak için ağa bağlanmaları gerekir. Bu, onları dış dünyaya ve saldırıya maruz bırakır. Bilgisayar korsanlığı, dolandırıcılık, gizlilik istilası, kurumsal/kişisel veriler vb. Çalmak gibi dolandırıcılık eylemlerini yerine getirmek için bilgisayarları kullanmak anlamına gelir. Siber suçlar her sene milyonlarca dolara mal olur. İşletmeler bu tür saldırılardan kendilerini korumak zorundalar.

Etik Hacking'in Uygunluğu: Etik Korsanlık, korsan, etik hackleme tanımında yukarıdaki bölümde belirtilen kurallara uyarsa geçerlidir. Uluslararası E-Ticaret Danışmanları Konseyi (*EC-Council*) "www.eccouncil.org", kişinin becerilerini test eden bir sertifika programı sunmaktadır. Sınavı geçenlere sertifika verilmektedir. Sertifikaların bir süre sonra yenilenmesi gerekiyor.

Hacker Kimdir?

Hacker, bilgisayar sistemleri ve/veya ağlarındaki zayıflığı bulan ve bunlardan yararlanan bir kişidir. Hacker'lar genellikle bilgisayar güvenliği bilgisine sahip nitelikli bilgisayar programcılarıdır. Bilgisayar korsanları, eylemlerinin niyetine göre sınıflandırılır. Aşağıdaki liste, bilgisayar korsanlarını niyetlerine göre sınıflandırmaktadır.

- 1. Beyaz Şapkalılar:** Tanımlanan zayıflıkları gidermek amacıyla sistemlere erişen bir bilgisayar korsanıdır. Ayrıca penetrasyon testi ve güvenlik açığı değerlendirmeleri yapabilirler.
- 2. Cracker (Siyah şapka):** Kişisel kazanç için bilgisayar sistemlerine yetkisiz erişim sağlayan bir bilgisayar korsanıdır. Amaç genelde kurumsal verileri çalmak, gizlilik haklarını ihlal etmek, banka hesaplarından para aktarmak vb.
- 3. Gri şapka:** Etik ve siyah şapka bilgisayar korsanları arasındaki bir hacker'dır. Zayıf yönlerini belirlemek ve sistem sahibine açıklamak için yetkisiz bilgisayar sistemlerine girer.

- 4. Haktivist:** Saldırıları sosyal, dini ve siyasi vb. Mesajları göndermek için kullanan bir bilgisayar korsanı. Bu genellikle web sitelerini ele geçirerek ve mesajı kaçırılan web sitesinde bırakarak yapılır.

SİBER SUÇ NEDİR?

Siber suç, bilgisayar virüslerini yaymak, çevrimiçi zorbalık yapmak, yetkisiz elektronik fon transferleri yapmak vb. gibi yasadışı faaliyetleri gerçekleştirmek için bilgisayarların ve ağların kullanılmasıdır. Çoğu siber suçlar internet üzerinden işlenir. Bazı siber suçlar cep telefonlarını kullanarak SMS ve çevrimiçi sohbet uygulamaları yoluyla da gerçekleştirilebilir.

SİBER SUÇ TÜRLERİ

Aşağıdaki liste, siber suçların ortak türlerini sunmaktadır:

- **Bilgisayar Dolandırıcılığı:** Bilgisayar sistemlerini kullanarak kişisel kazanç için kasıtlı aldatma.
- **Gizlilik ihlalleri:** E-posta adresleri, telefon numarası, hesap bilgileri gibi kişisel bilgilerin sosyal medyada, web sitelerinde vs.
- **Kimlik Hırsızlığı:** Birisinden kişisel bilgileri çalmak ve o kişiyi taklit etmek.
- **Telif hakkıyla korunan dosyaları/bilgileri paylaşma:** Bu, e-Kitaplar ve bilgisayar programları gibi telif hakkı korumalı dosyaları dağıtmayı içerir.
- **Elektronik fon transferi:** Banka bilgisayar ağlarına yetkisiz erişimle girmeyi ve yasadışı fon transferleri yapmayı içerir.
- **Elektronik para aklama:** Para aklamak için bilgisayarın kullanılmasını gerektirir.
- **ATM Dolandırıcılığı:** Hesap numarası ve PIN numaraları gibi ATM kartı ayrıntılarını önlemeyi içerir. Bu ayrıntılar, daha sonra ele geçirilen hesaplardan para çekmek için kullanılır.
- **Hizmet Reddi Saldırıları:** Sunucuları kapatmak için saldırmak amaçlı birden fazla yerde bilgisayar kullanmayı içerir.
- **Spam:** Yetkisiz e-postalar gönderir. Bu e-postalarda genellikle reklamlar bulunur.

BİLGİSAYAR SİSTEMLERİNİZDE POTANSİYEL GÜVENLİK TEHDİTLERİ

Bir bilgisayar sistemi tehdidi, veri kaybı veya bozulmasına veya donanımın ve/veya altyapının fiziksel olarak hasar görmesine neden olan her şeydir. Bilgisayar güvenlik tehditlerini nasıl tespit edeceğini bilmek, bilgisayar sistemlerini korumanın ilk adımıdır. Tehditler kasıtlı, kaza sonucu olabilir veya doğal felaketlerden kaynaklanabilir.

Bu yazıda sizi ortak bilgisayar sistemi tehditlerine ve sistemleri kendilerinden nasıl koruyabileceğinizi anlatacağız.

FİZİKSEL TEHDİTLER NELERDİR?

Fiziksel bir tehdit, bir olayın potansiyel bir nedeni olup, bilgisayar sisteminde kayıp veya fiziksel hasar meydana gelebilir.

Aşağıdaki liste fiziksel tehditleri üç (3) ana kategoriye ayırmaktadır;

- **Dahili:** Tehlikeler yangın, dengesiz güç kaynağı, donanımı barındıran odalardaki nem vb. içerir.
- **Dış:** Bu tehditlere Yıldırım, sel, deprem vb. Dahildir.
- **İnsan:** Bu tehditler, hırsızlık, altyapı ve/veya donanımın vandalizmini, bozulmasını, kazara veya kasıtlı hataları içerir.

Bilgisayar sistemlerini yukarıda belirtilen fiziksel tehditlere karşı korumak için, bir kuruluşun fiziksel güvenlik kontrolü önlemleri olmalıdır. Aşağıdaki liste, alınabilecek olası önlemlerin bazılarını göstermektedir:

Dahili: Yangını söndürmek için su kullanmayan otomatik yangın dedektörleri ve söndürücüler kullanılarak yangın tehditleri önlenabilir. Dengesiz güç kaynağı, voltaj kontrolörleri kullanılarak engellenebilir. Bilgisayar odasındaki nemi kontrol etmek için bir klima kullanılabilir.

Harici: Yıldırımdan korunma sistemleri, bilgisayar sistemlerini bu tür saldırılara karşı korumak için kullanılabilir. Yıldırımdan korunma sistemleri% 100 mükemmel değildir, ancak belli ölçüde, Yıldırım'ın hasara neden olma şansını düşürürler. Yüksek yerler bilgisayar sistemlerini, sellere karşı korumanın olası yollarından biridir.

İnsanlar: Hırsızlık gibi tehditler, kilitli kapılar kullanılarak engellenebilir ve bilgisayar odalarına erişimi sınırlı olabilir.

Fiziksel olmayan tehditler nelerdir?

Fiziksel olmayan bir tehdit, bir olayın potansiyel bir nedenidir ve sonuçta;

- Sistem verisinin kaybolması veya bozulması,
- Bilgisayar sistemlerine dayanan ticari işlemleri aksatır,
- Hassas bilgilerin kaybedilmesi,
- Bilgisayar sistemlerinde yasadışı izleme,
- Siber Güvenlik İhlalleri,
- Diğerleri

Fiziksel olmayan tehditler mantıksal (*logical*) tehditler olarak da bilinir. Aşağıdaki liste, fiziksel olmayan fiziksel tehditlerin ortak türüdür;

- Virüs
- Truvalılar (*Trojans*)
- Worms
- Casus (*Spyware*)
- Anahtar kaydediciler (*keylogger*)
- Adware (*Ücretsiz Reklam barındıran programlar.*)
- Hizmet Reddini Saldırıları (*Denial of Service Attacks*)
- Dağıtılmış Hizmet Reddetme Saldırıları (*DDoS*)
- Veriler gibi bilgisayar sistem kaynaklarına yetkisiz erişim
- Kimlik Avı (*Phishing*)
- Diğer Bilgisayar Güvenliği Riskleri

Bilgisayar sistemlerini yukarıda adı geçen tehditlere karşı korumak için bir organizasyonun mantıklı güvenlik önlemleri olması gerekir. Aşağıdaki liste, siber güvenlik tehditlerini korumak için uygulanabilecek bazı önlemleri göstermektedir.

Virüslere, Truva atlarına, solucanlara vb. karşı koruma sağlamak için bir kuruluş anti-virüs yazılımını kullanabilir. Anti-virüs yazılımına ek olarak, kuruluş, harici

depolama aygıtlarının kullanımı ve kullanıcı bilgisayarına yetkisiz programları indirmesi muhtemel web sitesini ziyaret etme konusunda da kontrol önlemleri alabilir.

Kimlik doğrulama yöntemleri kullanılarak bilgisayar sistem kaynaklarına yetkisiz erişim engellenebilir. Kimlik doğrulama yöntemleri, kullanıcı kimlikleri ve güçlü parolalar, akıllı kartlar veya biyometrik vb. şeklinde olabilir.

Saldırı tespit/önleme sistemleri, hizmet reddi saldırılarına karşı koruma sağlamak için kullanılabilir. Hizmet reddi saldırılarını önlemek için uygulanabilecek diğer önlemler de vardır.

ETİK HACKER OLMAK İÇİN GEREKLİ BECERİLER

Beceri, mevcut zaman ve kaynaklar içinde istediğiniz hedefleri gerçekleştirmenizi sağlar. Bir bilgisayar korsanı olarak, işi halletmenize yardımcı olacak beceriler geliştirmeniz gerekecek. Bu beceriler, nasıl programlanacağını, interneti kullanmayı, sorunları çözmede iyi öğrenmeyi ve mevcut güvenlik araçlarından faydalanmayı öğrenmeyi içerir.

Bu yazıda sizi bir hacker olarak bilmeniz gereken ortak programlama dilleri ve becerileri hakkında bilgilendireceğiz.

Bir programlama dili nedir?

Bir programlama dili, bilgisayar programlarını geliştirmek için kullanılan bir dildir. Geliştirilen programlar işletim sistemlerine göre değişebilir.

Neden program yapmayı öğreneceksin?

- Hacker'lar, sorun çözücü ve araç üreticileri olup, programlama yöntemlerini öğrenmek, sorunlara çözüm üretmenize yardımcı olacaktır.
- Programları bilgisayar korsanı olarak yazmanız, tamamlanması çok zaman alacağınız birçok görevi otomatikleştirmenize yardımcı olacaktır.
- Programları ayrıca, hedefleyeceğiniz uygulamalardaki programlama hatalarını belirlemenize ve bunlardan yararlanmanıza yardımcı olabilir.

- Tekerleği sürekli yeniden icat etmek zorunda değilsiniz ve kolaylıkla kullanılabilen birkaç açık kaynak programı bulunmaktadır. Mevcut uygulamaları özelleştirebilir ve ihtiyaçlarınıza göre yöntemlerinizi ekleyebilirsiniz.

Hangi dilleri öğrenmeliyim?

Bu sorunun cevabı, hedef bilgisayar sistemlerinize ve platformlarınıza bağlıdır. Bazı programlama dilleri yalnızca belirli platformlar için geliştirilir. Örnek olarak, Windows işletim sisteminde çalışan uygulamaları yazmak için C# kullanılır. Bu nedenle, hedefiniz Linux tabanlı sistemlere saldırı ise C# nasıl program yapılacağını öğrenmeniz mantıksız olur.

Bilgisayar Korsanlarına Kullanışlı Programlama Dilleri:

Sıra No	Dil	Açıklama	Platform	Amaç
1	HTML	Web sayfalarını yazmak için kullanılan dil.	Çapraz platform	Giriş formları ve diğer veri girişi yöntemleri web'de veri almak için HTML formlarını kullanır. HTML yazabilir ve yorumlayabilir, koddaki zayıflıkları tanımlamanıza ve kullanmanıza yardımcı olur.
2	Javascript	İstemci tarafı komut dosyası dili	Çapraz platform	JavaScript kodu istemci tarayıcısında yürütülür. Kaydedilmiş çerezleri okumak ve çapraz site komut dosyası yapmak için bunu kullanabilirsiniz.
3	PHP	sunucu tarafı komut dosyası dili	Çapraz platform	PHP en çok kullanılan web programlama dillerinden biridir. HTML formlarını işlemek için kullanılır ve diğer özel görevler gerçekleştirir. PHP'de bir web sunucusundaki ayarları değiştiren ve sunucuyu saldırılara açık hale getiren özel bir uygulama yazabilirsiniz.

Sıra No	Dil	Açıklama	Platform	Amaç
4	SQL	Veritabanı ile iletişim kurmak için kullanılan dil	Çapraz platform	SQL enjeksiyonunu kullanarak, zayıf olan web uygulaması oturum açma algoritmalarını atlamak, verileri veri tabanından silmek vb.
5	Python Ruby Bash Perl	Üst düzey programlama dilleri	Çapraz platform	Otomasyon araçları ve komut dosyaları geliştirmeniz gerektiğinde kullanışlı oluyorlar. Kazanılan bilgi, mevcut araçları anlama ve özelleştirme için kullanılabilir.
6	C & C++	Üst düzey programlama dilleri	Çapraz platform	Kendi kabuk kodlarını, istismarlarını, kök setlerini yazmanız veya mevcut olanları anlamanız ve genişletmeniz gerektiğinde kullanışlı oluyorlar.
7	Java CSharp Visual Basic VBScript	Diğer		Bu dillerin kullanışlılığı senaryonuza bağlıdır.



Çapraz platform, belirli dili kullanarak geliştirilen programların Windows, Linux tabanlı, MAC vb. gibi farklı işletim sistemlerine dağıtılabileceği anlamına gelir.

2017'DE ETİK HACKİNG İÇİN EN İYİ 20 ARAÇ

Hacking Araçları Nedir?

Hacking Tools, bilgisayar sistemleri, web uygulamaları, sunucular ve ağlardaki zayıflıkları bulmanıza ve bunlardan yararlanmanıza yardımcı olan bilgisayar programları ve komut dosyalarıdır. Piyasada bulunan çeşitli araçlar mevcut. Bazıları açık kaynak, bazıları ticaridir. Bu listede, web uygulamalarının, sunucuların ve ağların Etik Hacking'i için en iyi 20 aracı listeliyoruz.



2017 ??

2018 ??

Netsparker: Netsparker, web uygulamalarınızda ve web hizmetlerinizde otomatik olarak SQL Injection, XSS ve diğer güvenlik açıklarını bulabilen, kullanımı kolay bir web uygulama güvenlik tarayıcısıdır. Kurum içi ve SAAS çözümü olarak mevcuttur.

Acunetix WVS: Acunetix, önde gelen web güvenlik açığı tarayıcısıdır. Bu yaygın olarak beğeni toplayan araç, en gelişmiş SQL Enjeksiyon ve XSS kara kutu tarama teknolojisini sunar.

Burp Suite: Burp Suite, web uygulamalarının Güvenlik Testlerini gerçekleştirmek için kullanışlı bir platformdur.

Ettercap: Ettercap etik bir hack aracıdır. Etkin ve pasif diseksiyonu destekler; ağ ve ana bilgisayar analizi için özellikler içerir.

Aircrack: Aircrack, güvenilir bir ahlaki korsanlık aracıdır. Savunmasız kablosuz bağlantıları çürütüyor. WEP WPA ve WPA 2 şifreleme Anahtarları ile güçlendirilmiştir.

Angry IP Scanner: Angry IP Scanner, açık kaynaklı ve çapraz platformlara yönelik etik hack aracıdır. IP adreslerini ve bağlantı noktalarını tarar.

GFI LanGuard: GFI LanGuard, ağları güvenlik açıklarını tarayan etik bir araçtır. İsteğe bağlı olarak 'sanal güvenlik danışmanınız' gibi davranabilir. Her cihazın bir varlık envanteri oluşturmanıza olanak tanır.

Savvius: Etik bir hack aracıdır. Savvius paket istihbaratıyla ağ sorunlarını daha hızlı ve daha iyi teşhis edebilir.

QualysGuard: Qualys yetkili servisi, işletmelerin güvenlik ve uyumluluk çözümlerini hızlandırmalarına yardımcı olur. Aynı zamanda dijital dönüşüm girişimleri için güvenlik geliştirir. Bu araç ayrıca çevrimiçi bulut sistemlerinin performans açığını kontrol edebilir.

WebInspect: WebInspect, etik hack tekniklerine izin veren otomatik dinamik uygulama güvenliği testidir. Karmaşık web uygulamaları ve hizmetlerinin kapsamlı dinamik analizi sağlar.

L0phtCrack: L0phtCrack 6 yararlı şifre denetim ve kurtarma aracıdır. Yerel makineler ve ağlar üzerindeki parola güvenlik açığını tanımlar ve değerlendirir.

RainbowCrack: RainbowCrack, ahlaki korsanlık için yaygın olarak kullanılan bir şifre kırma aracıdır.

IKECrack: IKECrack açık kaynak kimlik doğrulama crack aracıdır. Bu etik hack aracı, kaba kuvvet veya sözlük saldırısı için tasarlanmıştır. Bu araç aynı zamanda şifreleme görevlerini gerçekleştirmeye de olanak tanır.

IronWASP: IronWASP de ahlaki korsanlık için açık kaynaklı bir yazılımdır. Web uygulaması güvenlik açığı testidir. Kullanıcılar özel güvenlik tarayıcılarını kullanarak özelleştirecek şekilde tasarlanmıştır.

Medusa: Medusa, çevrimiçi acımasız, hızlı, paralel şifre kırıcı etik hack aracından biridir. Bu araç aynı zamanda ahlaki korsanlık için yaygın olarak kullanılmaktadır.

SQLMap: SQL Injection zayıf yönlerini saptama ve kullanma sürecini otomatikleştirir. Açık kaynak ve çapraz platformdur. Aşağıdaki veri tabanı motorlarını destekler.

- **Cain&Abel:** Cain&Abel, bir Microsoft İşletim Sistemi şifre kurtarma aracıdır.
-

SOSYAL MÜHENDİSLİK NEDİR?

Sosyal mühendislik, bir bilgisayar sisteminin kullanıcılarını, bir bilgisayar sistemine yetkisiz erişim elde etmek için gizli bilgileri açığa çıkarma sanattır. Terim aynı zamanda, sınırlı erişimli binalara erişmek veya kullanıcıları arka kapı yazılımı yüklemeye teşvik etmek için insan mutluluğunu, açgözlülüğünü ve merakı kullanmak gibi faaliyetleri de içerebilir.

Bilgisayar korsanlarının kimliğini kullanan kullanıcıları hayati oturum açma bilgilerini serbest bırakmaları için kullandığı hileleri bilmek, bilgisayar sistemlerini korumak açısından temel bir gerekliliktir. Bu yazıda sizi ortak sosyal mühendislik tekniklerine ve bunlara karşı güvenlik önlemlerini nasıl hazırlayabileceğinizi anlatacağız.

Bilgi Toplama: Bu, ilk etapta, amaçlanan kurban hakkında mümkün olduğu kadar çok şey öğrenir. Bilgiler, şirket web sitelerinden, diğer yayınlardan ve bazen hedef sistemin kullanıcılarıyla konuşarak toplanır.

Saldırıyı Planla: Saldırganlar saldırıyı nasıl yürütmek istediğini açıklar.

Saldırma Araçları: Bunlar, bir saldırganın saldırıyı başlatırken kullanacağı bilgisayar programlarını içerir.

Saldırı: Hedef sistemdeki zayıf noktaları sömürür.

Edinilen bilgileri kullanın: Ev hayvanı isimleri, organizasyon kurucularının doğum tarihleri vb. gibi sosyal mühendislik taktikleri sırasında toplanan bilgiler, şifre tahminleri gibi saldırılarda kullanılır.

Sosyal mühendislik, yetkisiz kaynaklara erişmek için insan unsurlarını istismar etme sanatıdır. Sosyal mühendisler, kullanıcıları hassas bilgileri açığa vurmak için kandırmak için çeşitli teknikler kullanırlar. Kuruluşların sosyal mühendislik önlemlerine sahip güvenlik politikaları olması gerekir.

KRİPTOGRAFI EĞİTİMİ:

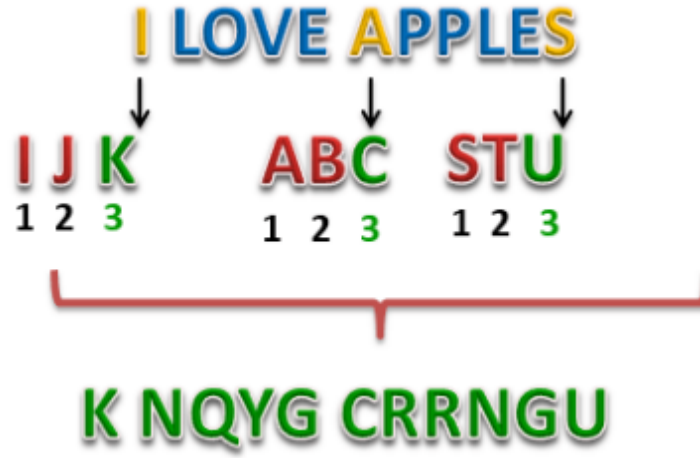
KRİPTOGRAFI, RC4, CRYPTOOOL

Bilgi: İş, organizasyon, askeri operasyonlar vb. faaliyetlerin yürütülmesinde hayati bir rol oynar. Yanlış eldeki bilgiler, iş kaybına veya felaket sonuçlarına neden olabilir. İletişim güvenliğini sağlamak için, bir işletme bilgi şifrelemek için kriptolojiyi kullanabilir. Kriptoloji, bilgiyi insan dışı okunabilir biçime dönüştürmeyi içerir ve tersi de geçerlidir.

KRİPTOGRAFI NEDİR?

Kriptografi, bilginin gerçek anlamını gizleyen teknikleri insan dışı okunabilir formatlara dönüştürerek incelemek ve uygulamaktır. Bir örnek yardımıyla bunu açıklayalım. "I LOVE APPLES" mesajını göndermek istediğinizi varsayarsak, tüm harfleri alfabede bulunan üçüncü ardışık harfle değiştirebilirsiniz. Şifreli mesaj "KNQYG CRRNGV" olacaktır. Mesajımızı çözmek için, şifresini çözmek istediğimiz harfi kullanarak alfabedeki üç harfi geri getirmeliyiz. Aşağıdaki resim, dönüşümün nasıl yapıldığını göstermektedir.

Key:



Basit Bir Şifreleme Örneği

Bilgiyi insan olmayan okunabilir biçime dönüştürme işlemi, **şifreleme** (*encryption*) olarak adlandırılır. Şifrelemeyi tersine çevirme işlemine şifre **çözme** (*decryption*) denir.

Şifre çözme işlemi, yalnızca bilgilerin meşru alıcıları tarafından bilinen **gizli bir anahtar** (*secretkey*) kullanılarak yapılır. Anahtar gizli mesajların şifresini çözmek için kullanılır. Bu, iletişimi güvence altına alır, şifreli bilgi bir **cipher** olarak bilinir.

KRİPTO ANALİZİ NEDİR?

Kripto analizi, iletileri şifrelemek için kullanılan anahtarı kullanmadan şifreli iletileri şifresini çözmeye çalışmanın sanatıdır. Kripto analiz, şifreleri çözmek için matematiksel analiz ve algoritmalar kullanır. Kripto analiz ataklarının başarısı;

- Kullanılabilir zaman miktarı
- Kullanılabilir bilgisayar gücü
- Depolama kapasitesi mevcut

Aşağıda, sıkça kullanılan Kripto analiz saldırılarının listesi verilmektedir;

Kaba kuvvet saldırısı (Brute force attack): Bu saldırı türü, daha sonra şifrelenecek ve orijinal şifrelere kıyasla düz metinlerin olası tüm mantıksal kombinasyonlarını tahmin etmeye çalışan algoritmalar kullanır.

Sözlük saldırısı (Dictionary attack): bu saldırı türü, düz metin veya anahtarla eşleşme bulmak için bir sözcük listesini kullanır. Çoğunlukla şifrelenmiş parolaları kırmaya çalışırken kullanılır.

Gökkuşaklı Tablosu Saldırısı (Rainbowtableattack): Bu tür saldırılar, şifre metnini, eşleşme bulmak için önceden hesaplanmış karmalara (*hash*) kıyasla karşılaştırır.

KRİPTOLOJİ NEDİR?

Kriptoloji, kriptografi (*cryptography*) ve şifreleme (*cryptanalysis*) teknikleri birleştirir.

Şifreleme Algoritmaları

MD5: Bu, Message-Digest 5'in kısaltmasıdır. 128-bit karma değerler oluşturmak için kullanılır. Teorik olarak, karmalar orijinal düz metne dönüştürülemez. MD5, şifrelerin şifrelenmesinin yanı sıra veri bütünlüğünü kontrol etmek için kullanılır. MD5 çarpışmaya dayanıklı değildir. Çarpışma direnci, aynı karma değerler üreten iki değer bulmada güçlüklerdir.

SHA: Güvenli Hash Algoritmasının kısaltmasıdır. SHA algoritmaları, bir mesajın özet gösterimini oluşturmak için kullanılır (*mesaj özet*). Çeşitli sürümleri vardır;

- SHA-0: 120 bit karma değerler üretir. Önemli kusurlar nedeniyle kullanımdan çekildi ve SHA-1 ile değiştirildi.
- SHA-1: 160 bit karma değerler üretir. MD5'in önceki sürümlerine benzer. Şifreleme zayıflığına sahiptir ve 2010 yılından beri kullanılması önerilmez.
- SHA-2: İki hash fonksiyonu, yani SHA-256 ve SHA-512 vardır. SHA-256, 32-bit kelimeler, SHA-512 ise 64-bit kelimeler kullanır.

RC4: Bu algoritma, akış şifreleri oluşturmak için kullanılır. Genellikle internet iletişimini şifrelemek için **Güvenli Yuva Katmanı (SSL)** ve kablosuz ağları güvenli hale getirmek için **Kablolu Eşdeğer Gizlilik (WEP)** gibi protokollerde kullanılır.

BLOWFISH: Bu algoritma, anahtarlanmış, simetrik olarak bloke edilmiş şifreler oluşturmak için kullanılır. Şifreleri ve diğer verileri şifrelemek için kullanılabilir.

Hacking Etkinliği: Bu pratik senaryoda, RC4 algoritmasını kullanarak basit bir şifre oluşturacağız. Daha sonra kaba kuvvet saldırısı kullanarak şifresini çözmeye çalışacağız. Bu alıştırmaya için şifreleme gizli anahtarının 24 bit olduğunu bildiğimizi varsayalım. Bu bilgiyi şifreyi kırmak için kullanacağız.

<https://www.cryptool.org/en/ct1-downloads> ilgili linkten indirin.

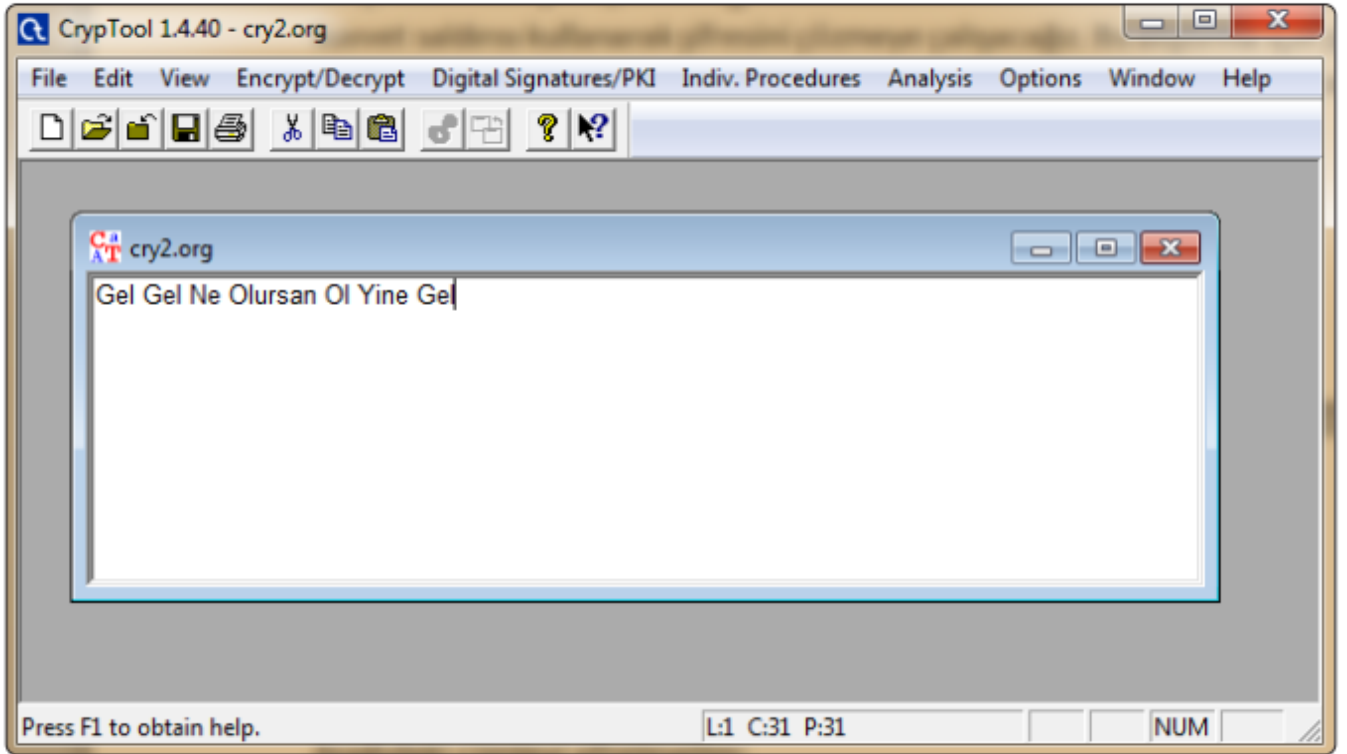
RC4 akış şifresini oluşturma

Aşağıdaki cümleyi şifreleyelim:

Gel Gel Ne Olursan Ol Yine Gel

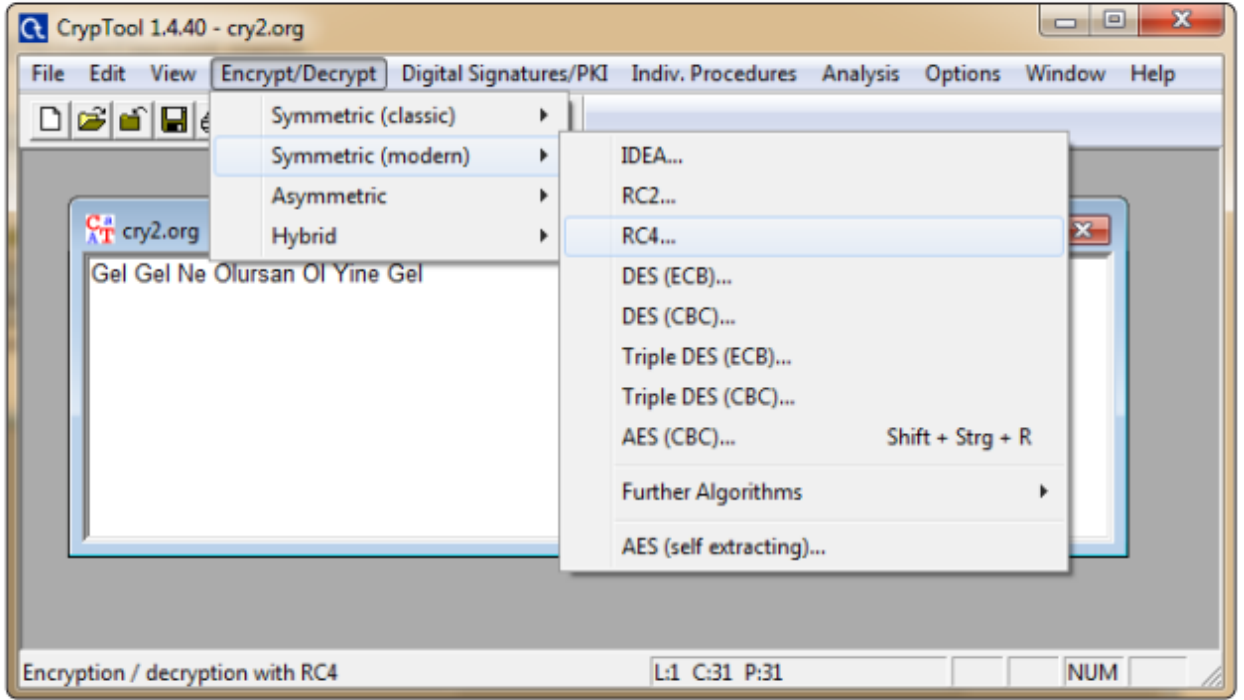
Kurduğumuz cryptool programımızı açalım. İlk gelen pencereyi kapatalım.

Yeni (New) basarak yeni bir pencere açalım.



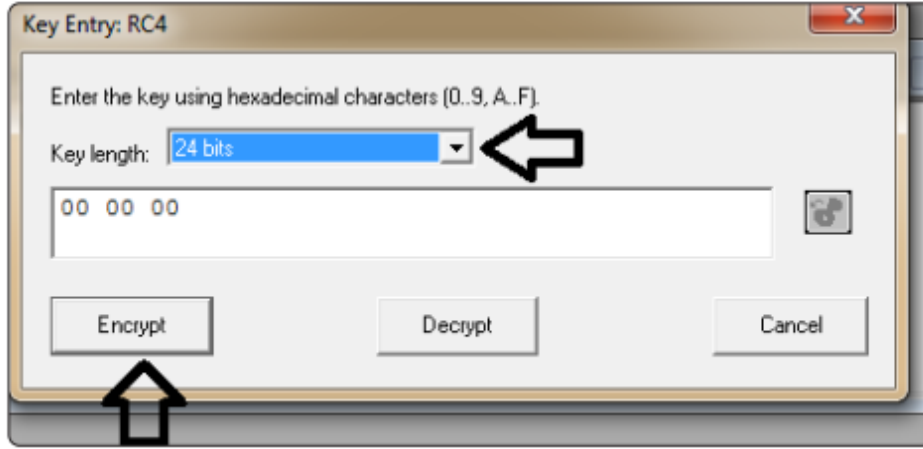
Şifrelenilecek Mesajı

Şifreleyelim. **Simetrik** (modern)'in üzerine gelin ve yukarıda gösterildiği gibi **RC4**'ü seçin. Sıradaki pencere açılacak.



Mesajı RC4 ile Şifreleyeceğimizi Belirtiyoruz.

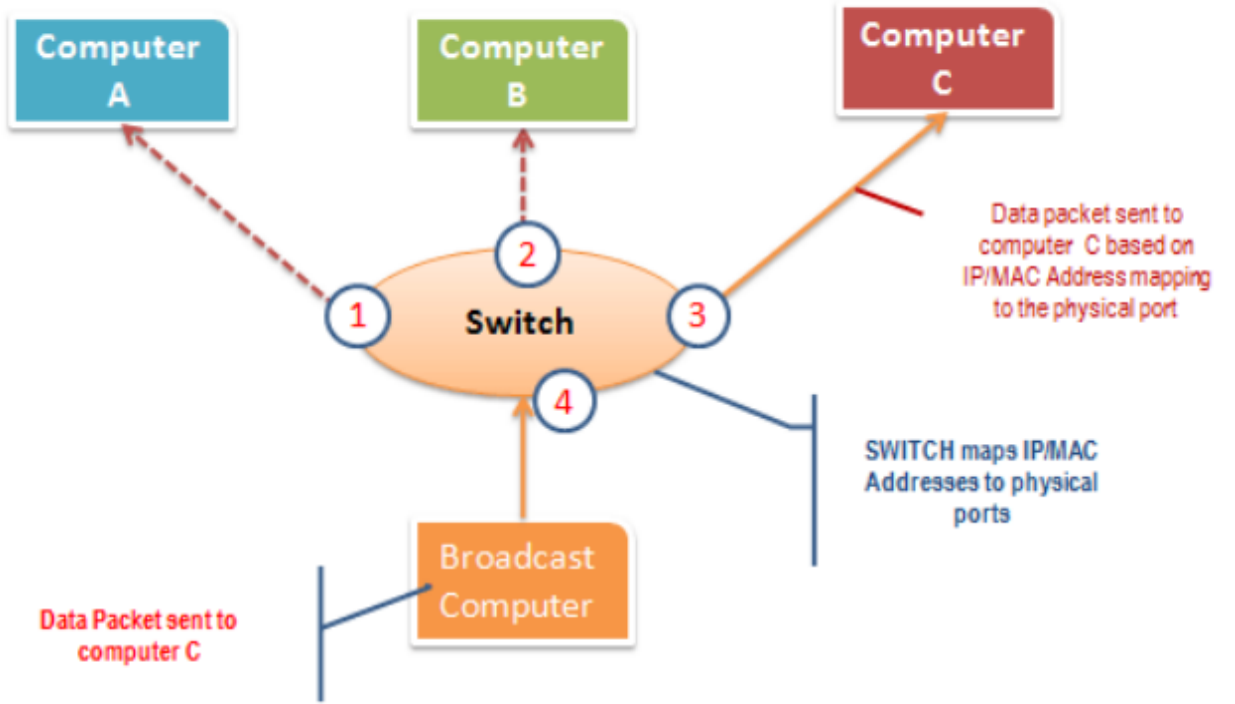
24- bite mesajımızı şifreliyoruz.



24-Bit ile Şifreliyoruz

Şifreleme anahtarı olarak **24 bit** seçin. Değeri **00 00 00** olarak ayarlayın. **Şifrele** (*Encrypt*) düğmesini tıklayın.

Bir anahtar farklı çalışır; IP/MAC adreslerini fiziksel bağlantı noktalarına eşler. Yayın iletileri, alıcı bilgisayarın IP/MAC adresi yapılandırmalarıyla eşleşen fiziksel bağlantı noktalarına gönderilir. Bu, yayın iletileri yalnızca alıcı bilgisayar tarafından görüldüğü anlamına gelir. Anahtarlar veri bağlantısı katmanında (*katman 2*) ve ağ katmanında (*katman 3*) çalışır. Aşağıdaki diyagram, anahtarın nasıl çalıştığını göstermektedir.



Switch Çalışma Prensibi

Pasif koklama, bir hub kullanan bir ağ üzerinden iletilen paketleri engelliyor. Algılanması zordur, çünkü pasif koklama denir. Göbek aynı zamanda ağ üzerindeki tüm bilgisayarlara yayın mesajları gönderdiğinden gerçekleştirmek kolaydır.

Aktif koklama, bir anahtar kullanan bir ağ üzerinden iletilen paketleri engelliyor. Bağlantılı şebekeleri, ARP Zehirlenmeyi ve MAC seleğini keşfetmek için kullanılan iki temel yöntem vardır.

Etkinlik: Bu pratik senaryoda, Wireshark'ı, veri paketlerini HTTP protokolü üzerinden ilettikçe dinlemek için kullanacağız. Bu örnekte, Wireshark'ı kullanarak şebekeyi kandırıp daha sonra güvenli iletişim kullanmayan bir web uygulamasına giriş yapacağız. [Http://www.techpanda.org/](http://www.techpanda.org/) adresindeki bir web uygulamasına giriş yapacağız.

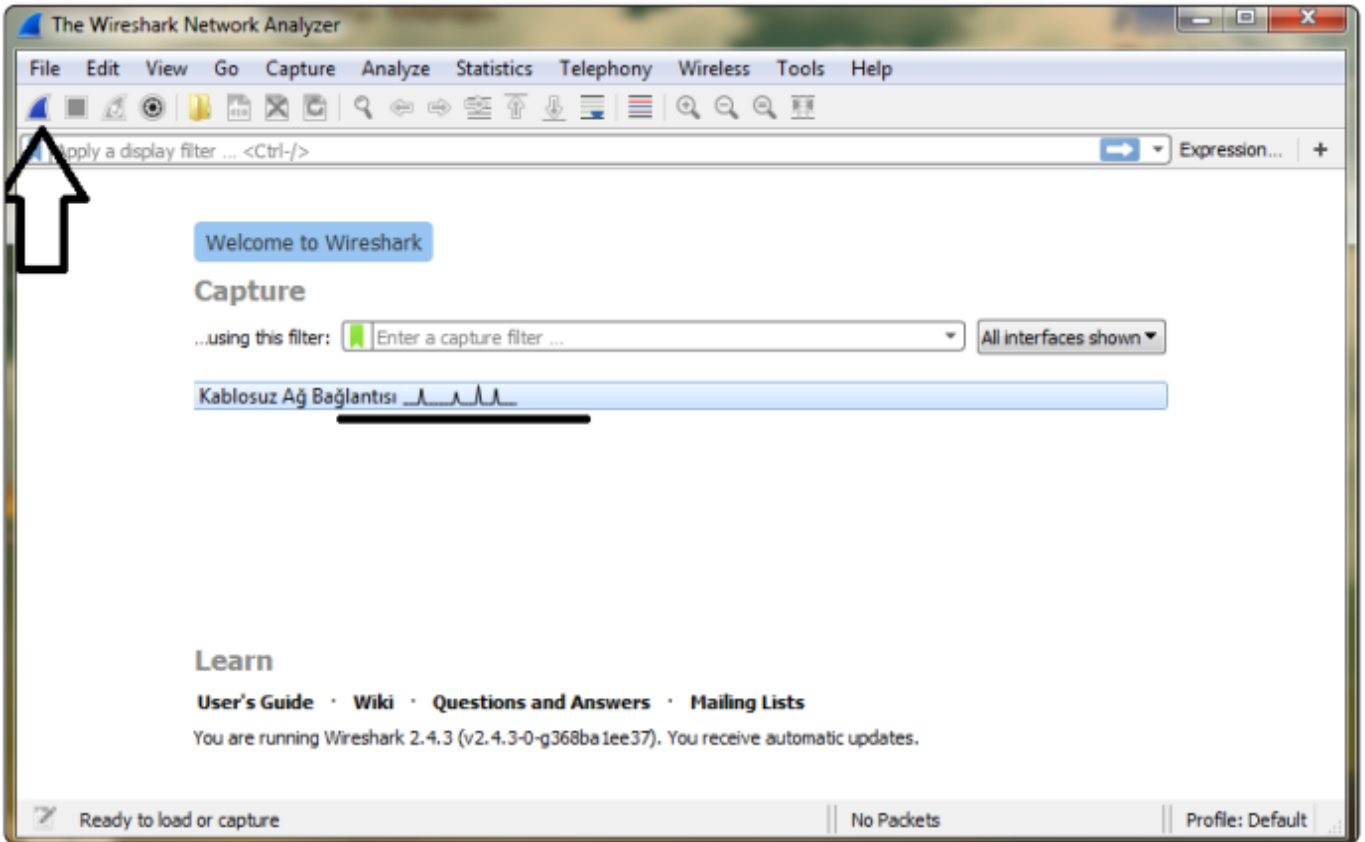


Yalnızca tanıtım amacıyla web uygulamasına giriş yapacağız. Teknik ayrıca, veri paketlerini, aynı ağda koklamak için kullandığınız bilgisayarlardan diğer bilgisayarlardan da koklamaktadır. Koklama yalnızca techpanda.org ile sınırlı değil aynı zamanda tüm HTTP ve diğer protokol veri paketlerini de koklar.

Wireshark'ı kullanarak ağları koklamak (Sniffer):

Wireshark'ı şu linkten indirin: <http://www.wireshark.org/download.html>

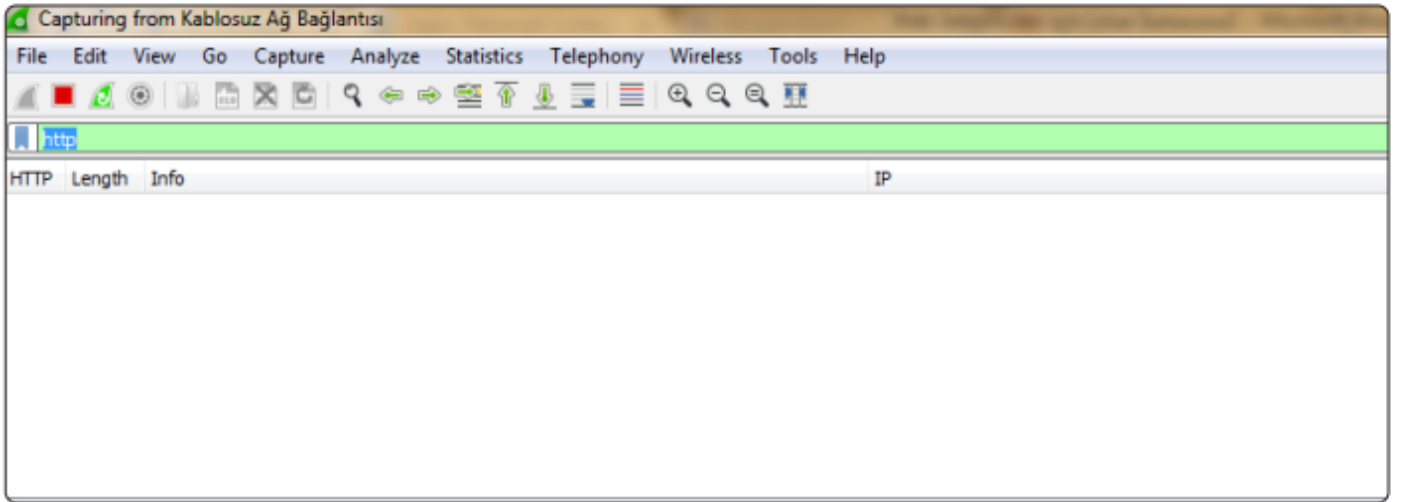
- Wireshark'ı açın
- Aşağıdaki ekranı alacaksınız.



WireShark

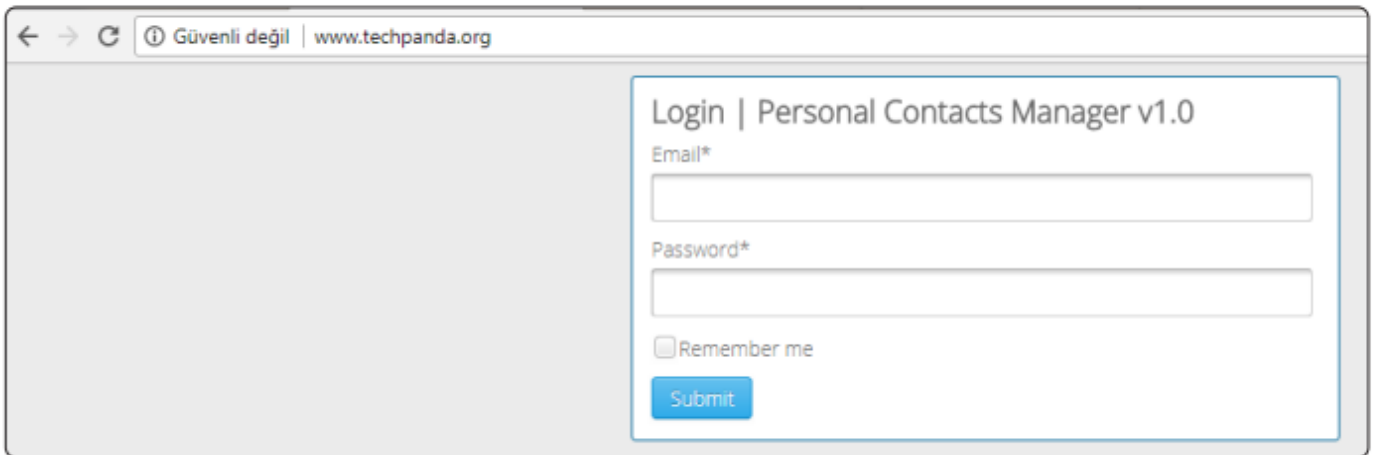
Okun gösterdiği başlat butonu ile ağı dinlemeye başlayın.

Aşağıdaki gibi ekranı alacaksınız.



Filtreleme Yapılıyor

http://www.techpanda.org/ adresine giderek paketlerin içeriğini inceleyelim.



Güvensiz Bir Web Siteyi Tarayıcımızla Açıyoruz

HTTP GET ile sayfa talebinde bulunuyoruz.

HTTP	Length	Info	IP
HTTP	531	GET / HTTP/1.1	HTTP
HTTP	1156	HTTP/1.1 200 OK (text/html)	HTTP
HTTP	519	GET /favicon.ico HTTP/1.1	HTTP
HTTP	545	HTTP/1.1 200 OK (image/x-icon)	HTTP

▶ Frame 786: 531 bytes on wire (4248 bits), 531 bytes captured (4248 bits) on interface 0 ▶ Ethernet II, Src: IntelCor_3a:67:59 (4c:eb:42:3a:67:59), Dst: ZyxelCom_9d:97:98 (a0:e4:cb:9d:97:98) ▶ Internet Protocol Version 4, Src: 192.168.1.35, Dst: 72.52.251.71 ▶ Transmission Control Protocol, Src Port: 54854, Dst Port: 80, Seq: 1, Ack: 1, Len: 477 ▶ Hypertext Transfer Protocol
▶ GET / HTTP/1.1\r\n Host: www.techpanda.org\r\n Connection: keep-alive\r\n Cache-Control: max-age=0\r\n User-Agent: Mozilla/5.0 (Windows NT 6.1; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/6

Ağ Paket Dinlemesi Yapılıyor

Bize dönüş olarak 3 adet daha sunucudan cevap (*response*) gelmektedir. Bize tarayıcıdan görünen ise kullanıcı adı ve şifresini isteyen bir form gözükecektir. Bu forma rasgele kullanıcı adı ve şifre girerek **POST** edelim.

Login | Personal Contacts Manager v1.0

Email*

Password*

☐ Remember me

E-Mail ve Şifre Giriliyor

Submit butonuna basarak gönderilen paketlerin içeriğine göz atalım.

HTTP	Length	Info	IP
HTTP	531	GET / HTTP/1.1	HTTP
HTTP	1156	HTTP/1.1 200 OK (text/html)	HTTP
HTTP	519	GET /favicon.ico HTTP/1.1	HTTP
HTTP	545	HTTP/1.1 200 OK (image/x-icon)	HTTP
HTTP	727	POST /index.php HTTP/1.1 (application/x-www-form-urlencoded)	HTTP
HTTP	1213	HTTP/1.1 200 OK (text/html)	HTTP

▶ Frame 2168: 727 bytes on wire (5816 bits), 727 bytes captured (5816 bits) on interface ▶ Ethernet II, Src: IntelCor_3a:67:59 (4c:eb:42:3a:67:59), Dst: ZyxelCom_9d:97:98 (a0:e4: ▶ Internet Protocol Version 4, Src: 192.168.1.35, Dst: 72.52.251.71 ▶ Transmission Control Protocol, Src Port: 54936, Dst Port: 80, Seq: 1, Ack: 1, Len: 673 ▶ Hypertext Transfer Protocol ▶ HTML Form URL Encoded: application/x-www-form-urlencoded ▶ Form item: "email" = "doguhanelma@hotmail.com" ▶ Form item: "password" = "123456"

HTTP Protokolünün Ne Kadar Güvensiz Olduğu Görüyoruz

Görüldüğü gibi formda yer alanların içerikleri açık (*plaintext*) olarak okuyabilmekteyiz. Bu gibi HTTPS uygulanmamış kimlik doğrulama sistemlerinde şifrenizin çalınabileceği aklınızdan çıkmamalıdır.

MAC ADRES TAŞMASI (MAC FLOODİNG)

MAC Adres Taşması (*MAC Flooding*), ağı aktif olarak dinleme yöntemlerinden biridir. Atak yapan bilgisayarın hızlı bir şekilde gönderdiği binlerce **MAC** (*Media Access Control – Ortam Erişim Kontrolü*) adresi ile anahtarlayıcının sahip olduğu MAC adres tablosu dolarsa bu olay **Mac Flooding** olarak adlandırılır. Bu durum iletişim ortamında güvenliğin sağlanamaması, ağ hızının düşürülmesi gibi sorunlara sebep olur.

Atak yapan bilgisayar tarafından anahtarlayıcıya hızlı bir şekilde ard arda sahte MAC adresleri gönderilir. Hafızası dolan anahtarlayıcı **çoklayıcı** (*hub*) mantığı ile çalışmaya başlar. Yani anahtarlayıcı, üzerine gelen ağ trafiğini sadece iletişime geçeceği bilgisayara değil, atağı gerçekleştiren bilgisayar dahil ağdaki tüm bilgisayarlara gönderir (*sniffer işlemi hub özellikli cihazlarla yapılır*). Bu şekilde atağı gerçekleştiren bilgisayar güvenlik ihlali yaparak anahtarlayıcıya

bağlı tüm giriş yeri trafiğini dinlenmiş olur. Bu işlemi gerçekleştirecek yani anahtarlayıcının MAC adres tablosunu sahte mac adresleriyle doldurabilecek yazılımlar mevcuttur.

MAC Flooding Karşı Önemler: Bazı anahtarların bağlantı noktası güvenlik özelliği vardır. Bu özellik, portlardaki MAC adreslerinin sayısını sınırlamak için kullanılabilir. Anahtar tarafından sağlanana ek olarak güvenli bir MAC adres tablosunu korumak için de kullanılabilir.

Özetle:

- Ağ koklama paketleri ağ üzerinden iletildiği için onları yakalamaktadır.
- Pasif koklama, bir hub kullanan bir ağ üzerinde yapılır. Algılamak zordur.
- Aktif koklama, bir anahtar kullanan bir ağ üzerinde yapılır. Algılanması kolaydır.
- MAC Flooding, sahte MAC adresleri ile MAC tablosu adres listesini sular altına alır. Bu, anahtarın bir HUB gibi çalışmasını sağlar.
- Yukarıda özetlendiği gibi güvenlik önlemleri, ağın koklamaya karşı korunmasına yardımcı olabilir.

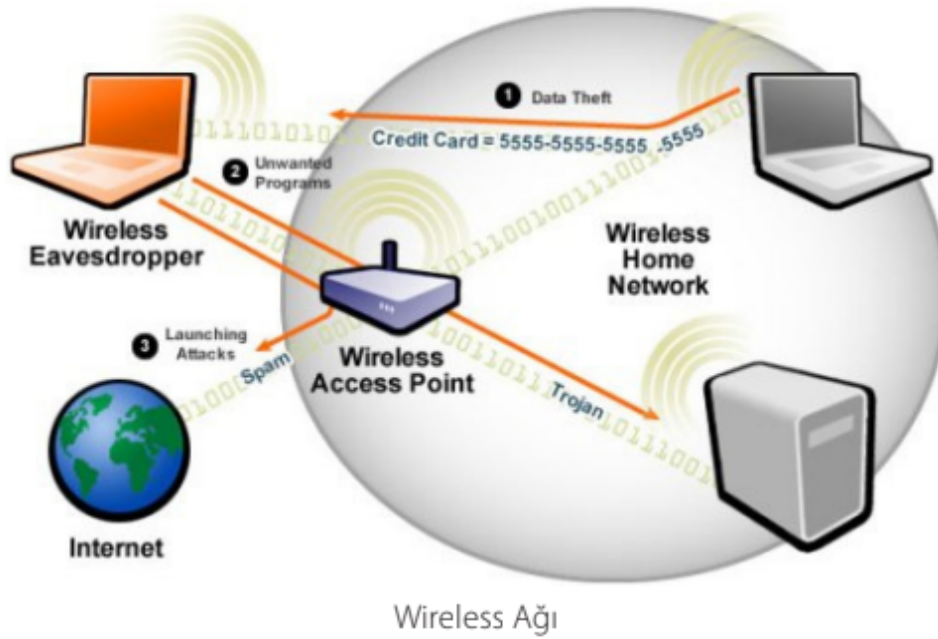
WİFİ (KABLOSUZ) AĞI

Kablosuz ağlara yönlendiricinin iletim yarıçapı içindeki herkes erişebilir. Bu onları saldırılara açık hale getirir. Sıcak noktalar havaalanları, restoranlar, parklar gibi kamuya açık yerlerde mevcuttur.

Bu yazıda, kablosuz ağ güvenliği uygulamalarında zayıf noktaları kullanmak için kullanılan yaygın teknikler size tanıtılacaktır. Ayrıca, bu tür saldırılara karşı koruma sağlamak için koyabileceğiniz bazı önlemlere de bakacağız.

Kablosuz ağ nedir?

Kablosuz ağ, bilgisayarları ve diğer aygıtları birbirine bağlamak için radyo dalgalarını kullanan bir ağdır. Uygulama, OSI modelinin 1. Katmanı'nda (*fiziksel katman*) yapılır.



Kablosuz bir ağa nasıl erişilir?

Bir dizüstü bilgisayar, tablet, akıllı telefon gibi kablosuz ağa bağlı bir ayağa ihtiyacınız olacaktır. Ayrıca bir kablosuz ağ erişim noktasının iletim yarıçapının içinde olması gerekir. Çoğu aygıt (*kablosuz ağ seçeneği açıksa*), kullanılabilir ağların listesini sağlar. Eğer ağ parola korumalı değilse, o zaman sadece bağlanmaya tıklamanız gerekir. Şifre korumalıysa, o zaman erişebilmek için şifreye ihtiyacınız olacaktır.

Kablosuz Ağ Kimlik Doğrulaması

Şebeke, kablosuz ağa bağlı bir cihaza sahip herkes tarafından kolayca erişilebildiğinden, çoğu şebeke şifre korumalıdır. En sık kullanılan kimlik doğrulama tekniklerinden bazılarına göz atalım.

WEP

WEP, Kabloluya Eşdeğer Gizlilik'in baş harfleridir. IEEE 802.11 WLAN standartları için geliştirildi. Amacıyla kablolu ağlar tarafından sağlanan eşdeğer gizlilik sağlamaktır. WEP, gizlice korunmak için ağ üzerinden iletilen verileri şifrelemek suretiyle çalışır.

WEP Kimlik Doğrulaması

Açık Sistem Kimlik Doğrulaması (OSA): Bu yöntem, yapılandırılmış erişim ilkesine dayalı istenen istasyon doğrulamasına erişim izni verir.

Paylaşılan Anahtar Doğrulaması (SKA): Bu yöntem, erişim isteyen istasyona şifreli bir zorlama gönderir. İstasyon, soruyu anahtarı ile şifreler ve yanıt verir. Şifreli erişim AP değeriyle eşleşirse, erişim sağlanır.

WEP Zayıflığı

WEP'in önemli tasarım kusurları ve zayıf yönleri vardır.

Paketlerin bütünlüğü, **Çevrimsel Fazlalık Kontrolü (CRC32)** kullanılarak kontrol edilir. CRC32 bütünlüğü denetimi, en az iki paket yakalamak suretiyle tehlikeye atılabilir. Şifrelenmiş akıştaki bitler ve sağlama toplamı, saldırgan tarafından değiştirilebilir ve böylece paket, kimlik doğrulama sistemi tarafından kabul edilir. Bu, ağa yetkisiz erişime neden olur.

WEP, akış şifreleri oluşturmak için RC4 şifreleme algoritmasını kullanır. Akış şifresi girişi bir başlangıç değeri (IV) ve bir gizli anahtardan oluşur. Başlangıç değeri uzunluğu (IV) 24 bit uzunluğunda iken gizli anahtar 40 bit veya 104 bit uzunluğunda olabilir. Hem başlangıç değerinin hem de sır uzunluğunun toplam uzunluğu 64 bit ya da 128 bit olabilir. Gizli anahtarın mümkün olan en düşük değeri, onu çatlamaı kolaylaştırır.

Zayıf Başlangıç değerleri kombinasyonları yeterince şifrelenmez. Bu onları saldırılara açık hale getirir. WEP, şifrelere dayalıdır; bu, sözlük saldırılarına açık hale getirir.

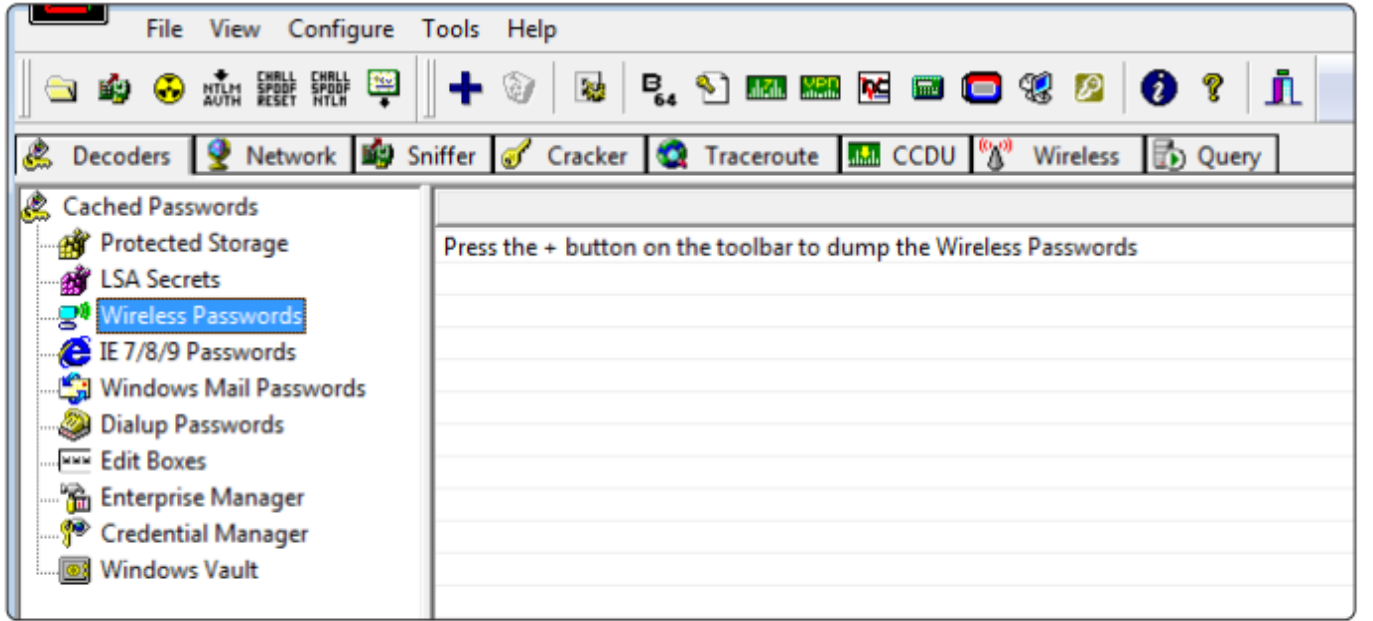
WPA

WPA, Wi-Fi Korumalı Erişim'in kısaltmasıdır. WEP'de bulunan zayıf yönlere tepki olarak Wi-Fi Alliance tarafından geliştirilen bir güvenlik protokolüdür. 802.11 WLAN'lardaki verileri şifrelemek için kullanılır. WEP'in kullandığı 24 bit yerine 48 bit daha yüksek Başlangıç Değerleri kullanır. Paketleri şifrelemek için geçici anahtarlar kullanır.

WPA Zayıf Yönleri

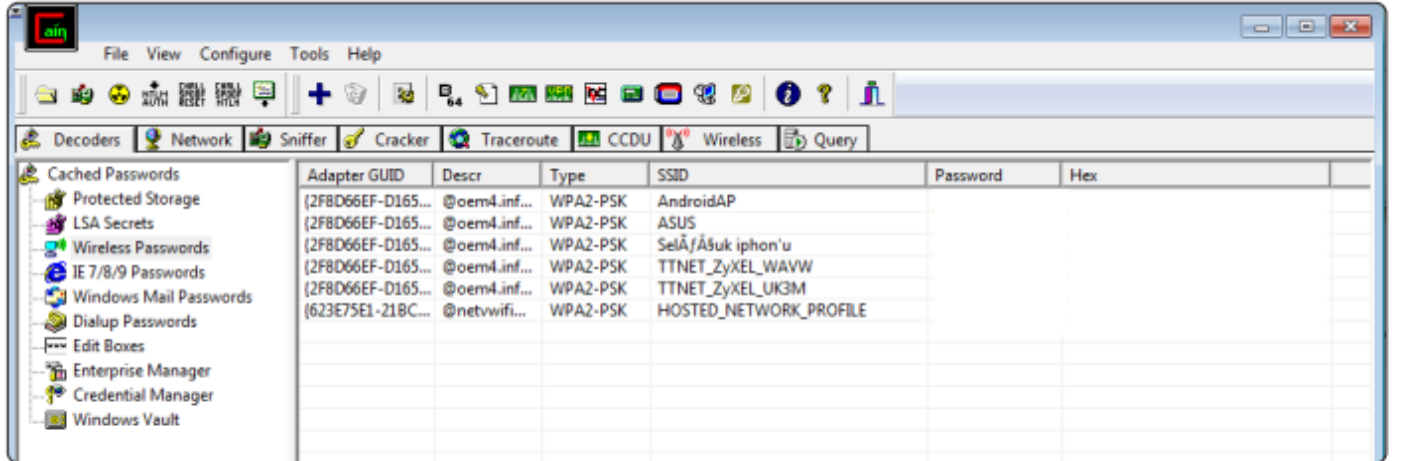
- Çarpışma önleme uygulaması kırılabilir.
- Hizmet reddi saldırılarına karşı savunmasızdır.
- Ön paylaşım anahtarları, parolaları kullanır. Zayıf parolalar sözlük saldırılarına açıktır.

Kablosuz Ağı Kırarak: Bu pratik senaryoda, Windows'da kayıtlı kablosuz ağ şifrelerini çözmek için Cain ve Abel'e gidiyoruz. Kablosuz ağların WEP ve WPA anahtarlarını çatlama için kullanılabilecek faydalı bilgiler de sağlayacağız.



Wireless Ağında Şifre Kırma

- Decoders sekmesinin seçili olduğundan emin olun ve soldaki gezinme menüsünden Kablosuz Şifreleri (*Wireless Passwords*)'ni tıklayın.
- Artı işaretli düğmeyi tıklayın.



Tüm Şifreler Kırılarak Şifreleri Döndürülmüştür

Listede çevremde olan Kablosuz ağların listesini görmekteyiz. "Password" kısmı da görülmekte olup; örnek resimde silinmiştir.